



Weekly IT Security Brief (Official-source-first) | 2026-06-07 06:05

Formatted for readability · Auto-generated



Weekly Summary

- Priority snapshot: 5 KEV-listed vulnerabilities are actively exploited in the wild (top 8 shown in this brief).
- Urgent patch focus: CVE-2026-28318(2026-06-19), CVE-2026-45247(2026-06-06), CVE-2022-0492(2026-06-05). Prioritize internet-facing and privileged systems first.
- Threat trend #1: Securing CI/CD in an agentic world: Claude Code Github action case. Tags CI/CD Frontier AI models Vulnerability Content types Research Products and services Microsoft Defender Topics Actionable threat insights AI and agents Defending against...
- Threat trend #2: Updating the taxonomy of failure modes in agentic AI systems: What a year of red teaming taught us. A surge in real-world attacks against agentic AI systems is reshaping how we think about risk. Based on 12 months of red teaming, this update...
- Recommended action this week: patch KEV/high-risk exposed services within 24 hours and tighten monitoring for anomalous login, command execution, and credential access patterns.



Report A: CVE Deep Dive (CISA KEV + NVD)

CVE-2026-28318

CVE Title	CVE-2026-28318 solarwinds/serv-u Unknown Type
CVE Description	SolarWinds Serv-U is susceptible to specially crafted POST requests that crash the Serv-U service without authentication using Content-Encoding: deflate. Mitigation steps are provided to secure customer environments in the SolarWinds Trust Center if you are unable to deploy the update
Root Cause	Authentication workflow has logical flaws allowing bypass.
Exploitation Prerequisite	Target service is network-reachable and accepts attacker-crafted unauthorized requests.
Exploit Path	Unauthorized request -> auth bypass -> sensitive data access / privileged operations.
Affected Products	solarwinds/serv-u
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-19
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-28318

CVE-2026-45247

CVE Title	CVE-2026-45247 mirasvit/full_page_cache_warmer Remote Code Execution
CVE Description	Mirasvit Full Page Cache Warmer for Magento 2 before version 1.11.12 contains a PHP object injection vulnerability that allows unauthenticated attackers to achieve remote code execution by supplying a crafted serialized PHP object in the CacheWarmer cookie. Attackers can exploit the unrestricted call to PHP's native unserialize() function combined with gadget chains available in Magento and its dependencies to...
Root Cause	Unsafe deserialization or input-handling flaws enable arbitrary code execution.
Exploitation Prerequisite	Relevant endpoint is exposed and unpatched.
Exploit Path	Malicious request/payload -> vulnerability trigger -> remote command execution.
Affected Products	mirasvit/full_page_cache_warmer
Risk Score	9.8 (CRITICAL)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-06
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-45247

CVE-2022-0492

CVE Title	CVE-2022-0492 netapp/h300s_firmware Unknown Type
CVE Description	A vulnerability was found in the Linux kernel's cgroup_release_agent_write in the kernel/cgroup/cgroup-v1.c function. This flaw, under certain circumstances, allows the use of the cgroups v1 release_agent feature to escalate privileges and bypass the namespace isolation unexpectedly.
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	netapp/h300s_firmware, netapp/h300s, netapp/h410c_firmware, netapp/h410c, netapp/h410s_firmware
Risk Score	7.8 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2022-0492

CVE-2025-48595

CVE Title	CVE-2025-48595 google/android Integer Overflow
CVE Description	In multiple locations, there is a possible way to achieve code execution due to an integer overflow. This could lead to local escalation of privilege with no additional execution privileges needed. User interaction is not needed for exploitation.
Root Cause	Memory-safety weakness can cause memory corruption or unintended control flow.
Exploitation Prerequisite	Victim must process malicious content (web page/file/packet).
Exploit Path	Delivery of malicious content -> memory fault trigger -> code execution / crash.
Affected Products	google/android
Risk Score	8.4 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-05
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2025-48595

CVE-2024-21182

CVE Title	CVE-2024-21182 oracle/weblogic_server Unknown Type
CVE Description	Vulnerability in the Oracle WebLogic Server product of Oracle Fusion Middleware (component: Core). Supported versions that are affected are 12.2.1.4.0 and 14.1.1.0.0. Easily exploitable vulnerability allows unauthenticated attacker with network access via T3, IIOP to compromise Oracle WebLogic Server. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to al...
Root Cause	Use vendor advisories and patch notes for authoritative technical details.
Exploitation Prerequisite	Affected version is reachable through an exploitable path and remains unpatched.
Exploit Path	Attacker leverages public PoC or observed exploit chain for intrusion.
Affected Products	oracle/weblogic_server
Risk Score	7.5 (HIGH)
Exploited in the wild	Listed in CISA KEV
KEV remediation due date	2026-06-04
Mitigation	Apply vendor patches immediately, reduce internet exposure, harden WAF/ACL controls, and enable anomaly detection. Since active exploitation is observed, patch high-risk assets within 24 hours.
Source	https://www.cisa.gov/known-exploited-vulnerabilities-catalog
Source	https://nvd.nist.gov/vuln/detail/CVE-2024-21182

 Report A2: Newly Published CVEs (NVD, last 7 days)

CVE-2026-10153

CVE Title	CVE-2026-10153 待核實 XSS
CVE Description	A flaw has been found in westboy CicadasCMS up to 2431154dac8d0735e04f1fd2a3c3556668fc8dab. Impacted is the function Search of the file org/springframework/cache/support/AbstractCacheManager.java. This manipulation of the argument s causes cross site scripting. Remote exploitation of the attack is possible. The exploit has been published and may be used. This product follows a rolling release approach for continuous...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10153

CVE-2026-10154

CVE Title	CVE-2026-10154 待核實 Unknown Type
CVE Description	A vulnerability has been found in Dolibarr ERP CRM 23.0.0/23.0.1/23.0.2. The affected element is an unknown function of the file htdocs/user/messaging.php. Such manipulation of the argument ID leads to authorization bypass. The attack can be executed remotely. Upgrading to version 23.0.3 is sufficient to fix this issue. The name of the patch is 119b3606c7a701747a57a1f18b1a9e7666f678e2. It is suggested to upgrade the...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10154

CVE-2026-10155

CVE Title	CVE-2026-10155 待核實 SQL Injection
CVE Description	A vulnerability was found in Bdtask Multi-Store Inventory Management System 1.0. The impacted element is the function accounts_report_search of the file application/modules/accounts/controllers/Accounts.php of the component Accounts Report Handler. Performing a manipulation of the argument dtpToDate results in sql injection. The attack is possible to be carried out remotely. The exploit has been made public and coul...
Affected Products	待核實
Risk Score	4.7 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10155

CVE-2026-10156

CVE Title	CVE-2026-10156 待核實 Unknown Type
CVE Description	A vulnerability was determined in Open5GS up to 2.7.7. This affects the function handle_amf_info in the library /lib/sbi/nnrf-handler.c of the component nf-instances Endpoint. Executing a manipulation of the argument nf_info_pool can lead to resource consumption. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized. Applying a patch is advised to resolve this issue. Th...
Affected Products	待核實
Risk Score	4.3 (MEDIUM)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10156

CVE-2026-10157

CVE Title	CVE-2026-10157 待核實 Improper Authentication
CVE Description	A vulnerability was identified in Open5GS up to 2.7.6. This impacts an unknown function of the file src/amf/ngap-handler.c of the component NGAP PathSwitchRequest Message Handler. The manipulation leads to improper authentication. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The identifier of the patch is a188e36b1741ffc2252133f59b1bda4f14d3cb5c. It is suggeste...
Affected Products	待核實
Risk Score	7.3 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10157

CVE-2026-10158

CVE Title	CVE-2026-10158 待核實 Buffer Overflow
CVE Description	A security flaw has been discovered in TRENDnet TEW-432BRP 3.10B20. Affected is the function formPortFw of the file /goform/formPortFw. The manipulation of the argument server_name results in stack-based buffer overflow. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The vendor explains: "This product has been EOL for 15 years (since 2009)....
Affected Products	待核實
Risk Score	8.8 (HIGH)
Source	https://nvd.nist.gov/vuln/detail/CVE-2026-10158



Report B: Threat Intelligence News (last 7 days)

Headline: Securing CI/CD in an agentic world: Claude Code Github action case

Source	Microsoft Security Blog
Published	Fri, 05 Jun 2026 16:46:47 +0000
Key Takeaway	Tags CI/CD Frontier AI models Vulnerability Content types Research Products and services Microsoft Defender Topics Actionable threat insights AI and agents Defending against advanced tactics Microsoft Threat Intelligence discovered that Anthropic’s Claude Code GitHub Action could expose CI/CD workfl Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/06/05/securing-ci-cd-in-agentic-world-claude-code-github-action-case/

Headline: Updating the taxonomy of failure modes in agentic AI systems: What a year of red teaming taught us

Source	Microsoft Security Blog
Published	Thu, 04 Jun 2026 19:14:42 +0000
Key Takeaway	A surge in real-world attacks against agentic AI systems is reshaping how we think about risk. Based on 12 months of red teaming, this update introduces seven new failure modes, from supply chain compromise to goal hijacking, and the practical mitigations teams need now. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	technology/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.microsoft.com/en-us/security/blog/2026/06/04/updating-taxonomy-failure-modes-agentic-ai-systems-year-red-teaming-taught-us/

Headline: CISA Urges Stronger Security for Automatic Tank Gauge Systems

Source	CISA News
Published	Tue, 02 Jun 26 12:00:00 +0000
Key Takeaway	CISA Urges Stronger Security for Automatic Tank Gauge Systems
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-urges-stronger-security-automatic-tank-gauge-systems

Headline: CISA Announces Revised Town Hall Schedule to Engage with Stakeholders on Cyber Incident Reporting for Critical Infrastructure

Source	CISA News
Published	Tue, 26 May 26 12:00:00 +0000
Key Takeaway	CISA Announces Revised Town Hall Schedule to Engage with Stakeholders on Cyber Incident Reporting for Critical Infrastructure
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	critical infrastructure/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.cisa.gov/news-events/news/cisa-announces-revised-town-hall-schedule-engage-stakeholders-cyber-incident-reporting-critical

Headline: Seeking Counsel: Ongoing Targeted Campaign Against US Law Firms

Source	Mandiant Blog
Published	Fri, 05 Jun 2026 14:00:00 +0000
Key Takeaway	UNC3753 leverages voice phishing (vishing) and social engineering deception techniques to achieve remote access into corporate environments. Using these compromised personal laptops, they accessed corporate virtual desktop infrastructure (VDI) using native client platforms, such as Windows 365 (Win Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	LockBit
Target	defense/待核實
Technique	T1003.001,T1003.002,T1005
MITRE ATT&CK	T1003.001, T1003.002, T1005, T1020, T1021.001, T1021.004, T1036.005, T1046, T1052.001, T1053.005, T1059.001, T1059.003, T1070.001, T1083, T1133, T1135, T1204.002, T1219, T1486, T1547.001, T1553.002, T1562.001, T1566.004, T1567.002, T1569.002, T1572
Related CVEs	None
Link	https://cloud.google.com/blog/topics/threat-intelligence/targeted-campaign-us-law-firms/

Headline: Exploitation of KnowledgeDeliver via ViewState Deserialization Vulnerability

Source	Mandiant Blog
Published	Mon, 25 May 2026 14:00:00 +0000
Key Takeaway	Mandiant identified a critical vulnerability that allowed unauthenticated Remote Code Execution (RCE). This vulnerability stems from the use of identical pre-shared ASP.NET machine keys across multiple customer deployments. Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral movement.
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/japan
Technique	Malware Deployment
MITRE ATT&CK	Unverified
Related CVEs	CVE-2026-5426
Link	https://cloud.google.com/blog/topics/threat-intelligence/knowledgedeliver-viewstate-deserialization-vulnerability/

Headline: Reporting from Vegas: Networking, AI, and good boys

Source	Cisco Talos Blog
Published	Thu, 04 Jun 2026 18:00:59 GMT
Key Takeaway	Reporting from Vegas: Networking, AI, and good boys Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proac Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/reporting-from-vegas-networking-ai-and-good-boys/

Headline: Winning the cyber marathon with Tony Giandomenico

Source	Cisco Talos Blog
Published	Thu, 04 Jun 2026 12:05:31 GMT
Key Takeaway	Winning the cyber marathon with Tony Giandomenico Blog Intelligence Center Intelligence Center BACK Intelligence Search Email & Spam Trends Vulnerability Research Vulnerability Research BACK Vulnerability Reports Microsoft Advisories Incident Response Incident Response BACK Reactive Services Proacti Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://blog.talosintelligence.com/winning-the-cyber-marathon-with-tony-giandomenico/

Headline: New ChatGPT Lockdown Mode Limits Tools That Could Enable Data Exfiltration

Source	The Hacker News
Published	Sat, 06 Jun 2026 19:06:57 +0530
Key Takeaway	OpenAI has begun rolling out a new Lockdown Mode to ChatGPT for eligible personal accounts to reduce the risk of data exfiltration arising from prompt injection attacks. The feature is primarily designed for people and organizations that handle sensitive data and require stricter protection guarante Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ot/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/06/new-chatgpt-lockdown-mode-limits-tools.html

Headline: Free Apps Are Quietly Turning Smart TVs Into Web-Scraping Proxies for AI

Source	The Hacker News
Published	Sat, 06 Jun 2026 13:59:05 +0530
Key Takeaway	A researcher has reverse-engineered the iOS SDK that Bright Data embeds in consumer apps and documented how it turns devices, including always-on smart TVs, into exit nodes that relay web-scraping traffic for a data business Bright Data markets heavily to the AI industry. The company, the successor Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral move...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	ios/待核實
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://thehackernews.com/2026/06/free-apps-are-quietly-turning-smart-tvs.html

Headline: Opal Security Raises \$23 Million for AI-Native Identity Governance

Source	SecurityWeek
Published	Sat, 06 Jun 2026 10:15:00 +0000
Key Takeaway	Opal Security Raises \$23 Million for AI-Native Identity Governance - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity News Webcasts Virtual Events ICS: ICS Cybersecurity Conference Malware & Threats Cyberwarfare Cybercrime Data Breaches Fraud & Identity Theft Nation-State Ransomware Vulnerabilities Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/late...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/opal-security-raises-23-million-for-ai-native-identity-governance/

Headline: OWASP Incubator Project Helps Developers Find and Fix Vulnerable Dependencies in Seconds

Source	SecurityWeek
Published	Fri, 05 Jun 2026 16:35:02 +0000
Key Takeaway	CVE Lite CLI is a free, open-source command line tool that scans your projects in seconds and tells you exactly which included packages contain a vulnerability. OWASP Incubator Project Helps Developers Find and Fix Vulnerable Dependencies in Seconds - SecurityWeek SECURITYWEEK NETWORK: Cybersecurity Recommendation: prioritize vulnerable-version inventory, accelerate patching, and monitor anomalous logins/lateral mov...
Summary Engine	extractive-rules
Threat Actors	Not explicitly stated
Target	unknown-target
Technique	待核實
MITRE ATT&CK	Unverified
Related CVEs	None
Link	https://www.securityweek.com/owasp-incubator-project-helps-developers-find-and-fix-vulnerable-dependencies-in-seconds/

Sources (official/authoritative first)

<https://www.cisa.gov/known-exploited-vulnerabilities-catalog>

<https://nvd.nist.gov/>

<https://www.cve.org/>

[**https://attack.mitre.org/**](https://attack.mitre.org/)

[**https://www.microsoft.com/en-us/security/blog/**](https://www.microsoft.com/en-us/security/blog/)

[**https://www.cisa.gov/news-events/cybersecurity-advisories**](https://www.cisa.gov/news-events/cybersecurity-advisories)

[**https://www.mandiant.com/resources**](https://www.mandiant.com/resources)

[**https://blog.talosintelligence.com/**](https://blog.talosintelligence.com/)